Gestão de Projecto de Software

Licenciatura em Engenharia Informática

2024/2025

Segurança

A11

346

Definição de segurança

Segurança

- Segurança é a prática de proteger pessoas, ativos e informações contra ameaças e danos, sejam eles intencionais ou acidentais.
- Aplica-se em várias áreas, desde a segurança física e pessoal até à segurança digital e organizacional
- Pertinência
  - A segurança é essencial para a continuidade das operações, a protecção de activos e a confiança das pessoas e organizações nos ambientes em que operam

Segurança da Informação

- Conjunto de práticas e medidas adoptadas para proteger dados e sistemas de informação contra ameaças e acessos não autorizados.
- Preservar a Confidencialidade, Integridade e Disponibilidade das informações.
- Pertinência:
  - a protecção da informação é essencial para prevenir violações de dados, proteger a privacidade e assegurar a continuidade das operações.

347

Princípios Fundamentais da Segurança da Informação

- **Confidencialidade**
  - Garantir que a informação é acessível apenas a pessoas autorizadas.
  - Exemplo:
    - Encriptação de dados para que apenas quem possui a chave possa aceder à informação.
- **Integridade**
  - Assegurar que a informação não é alterada de forma não autorizada ou acidental.
  - Exemplo:
    - Utilização de assinaturas digitais para verificar a autenticidade e integridade de dados.
- **Disponibilidade**
  - Assegurar que a informação está disponível para ser utilizada por pessoas autorizadas quando necessário.
  - Exemplo:
    - Implementação de redundância e backups para evitar perda de dados e minimizar o tempo de inatividade.

348

348

Dimensões da Segurança da Informação (1/2)

- Para além dos três princípios principais (Confidencialidade, Integridade e Disponibilidade), existem outras dimensões importantes na segurança da informação, que podem ser ajustas em função da área onde o software é usado.

Autenticidade

- Garantir que a identidade dos utilizadores e entidades é verificada e que a informação vem de fontes confiáveis.
- Exemplo:
  - Utilização de métodos de autenticação, como autenticação multifator (MFA).

Responsabilidade (Accountability):

- Assegurar que as acções realizadas em sistemas de informação podem ser rastreadas até aos seus autores.
- Exemplo: Auditoria e monitorização de acções para garantir a responsabilidade dos utilizadores.

349

349

Dimensões da Segurança da Informação (2/2)

- **Privacidade**:
  - Proteger informações pessoais e assegurar que são tratadas de acordo com a legislação e os direitos dos indivíduos.
  - Exemplo:
    - Cumprimento do RGPD e implementação de políticas de Privacy by Design.

350

350

Ameaças à Segurança da Informação

- **Ameaças Físicas**
  - Riscos de danos físicos em sistemas, como incêndios, inundações e roubo de equipamentos.
- **Ameaças Lógicas**
  - Ciber-ataques como malware, phishing, ransomware e DDoS (ataque de negação de serviço).
- **Ameaças Internas**
  - Acessos não autorizados ou negligência por parte de funcionários ou colaboradores
- **Ameaças Externas**
  - Ataques de hackers, espionagem industrial e outras ameaças externas à organização.

351

351

Medidas de Segurança da Informação (1/2)

Para proteger as dimensões e princípios da segurança da informação, várias medidas e controlos podem ser implementados:

- **Controlo de Acesso**:
  - Restringir o acesso aos dados e sistemas com base nas funções dos utilizadores.
  - Exemplo
    - Políticas de acesso baseado em papéis (Role-Based Access Control - RBAC) e listas de controlo de acesso (ACL).
- **Criptografia**:
  - Encriptar dados em trânsito e em repouso para proteger a confidencialidade e integridade.
  - Exemplo
    - TLS para encriptação de dados em trânsito e AES para dados armazenados.

352

352

Medidas de Segurança da Informação (2/2)

- **Backup e Recuperação de Desastres**:
  - Implementar políticas de backup e planos de recuperação para assegurar a disponibilidade da informação.
  - Exemplo: Backups diários e planos de continuidade de negócios para desastres.
- **Monitorização e Auditoria**:
  - Monitorizar e auditar ações nos sistemas para garantir a integridade e a responsabilidade.
  - Exemplo
    - Logs de eventos e auditorias regulares para detetar comportamentos suspeitos.
- **Formação e Consciencialização dos Utilizadores**:
  - Formar colaboradores em práticas seguras para evitar erros humanos e reduzir o risco de ataques internos.
  - Exemplo
    - Formações regulares de sensibilização sobre phishing e políticas de segurança.

353

353

Normas e Regulamentos na Segurança da Informação

- **ISO/IEC 27001 / família ISO/IEC 27000**
  - Norma internacional para Sistemas de Gestão de Segurança da Informação (SGSI).
- **RGPD**
  - Regulamento Geral sobre a Protecção de Dados, que impõe requisitos rigorosos de privacidade e segurança de dados pessoais.
- NIST (National Institute of Standards and Technology):
  - https://www.nist.gov/cybersecurity
  - Publica directrizes como o NIST Cybersecurity Framework para ajudar organizações a gerir riscos de cibersegurança.

354

354

Processos de Gestão de Segurança da Informação

1. **Identificação de Riscos**
   - Identificar e classificar riscos de segurança com base na probabilidade e impacto.
2. **Avaliação de Riscos**
   - Avaliar a gravidade dos riscos e definir prioridades para tratamento
3. **Tratamento de Riscos**
   - Implementar medidas para mitigar ou aceitar riscos conforme a política de segurança da organização.
4. **Monitorização e Revisão Contínua**
   - Monitorizar regularmente as ameaças e rever as medidas de segurança para melhorar continuamente.

355

355

Boas Práticas de Segurança da Informação

- **Princípio do Menor Privilégio**
  - Os utilizadores só devem ter acesso ao que é estritamente necessário para a realização do seu trabalho.
- **Segurança por Camadas**
  - Utilizar múltiplas camadas de segurança para dificultar o acesso não autorizado (firewalls, antivírus, IDS/IPS)
- **Gestão de Vulnerabilidades**
  - Realizar auditorias de segurança regulares e manter software e sistemas atualizados com patches de segurança
- **Resposta a Incidentes**
  - Desenvolver e testar um plano de resposta a incidentes para agir rapidamente em caso de violações de segurança.

356

356



Família de normas ISO/IEC 27000

357

357

A família de normas ISO/IEC 27000 (1/2)

- conjunto de normas internacionais focadas na gestão da segurança da informação, desenvolvidas pela International Organization for Standardization (ISO) e pela International Electrotechnical Commission (IEC)
- O objectivo destas normas é fornecer orientações, especificações e boas práticas para a implementação da segurança dos sistemas

A norma central nesta família é a ISO/IEC 27001, que define os requisitos para implementar e manter um **Sistema de Gestão de Segurança da Informação (SGSI**). A partir desta, várias outras normas complementam diferentes aspectos da segurança da informação

358

358

A família de normas ISO/IEC 27000 (2/2)

- Integrar a família de normas ISO/IEC 27000 no processo de desenvolvimento de software é essencial para construir aplicações seguras e conformes com as regulamentações de segurança da informação.
- **Desde a fase de planeamento até à manutenção, estas normas orientam as organizações a protegerem dados sensíveis, gerirem riscos e garantirem a continuidade das operações**.

359

359

SO/IEC 27001: Sistema de Gestão de Segurança da Informação (SGSI)

Define os requisitos para estabelecer, implementar, manter e melhorar continuamente um SGSI. Esta norma foca-se numa abordagem baseada em riscos para proteger a informação e assegurar a conformidade com regulamentações de segurança

- **Componentes principais**
  - Contexto da organização
    - Definir o contexto e os objectivos da segurança da informação.
  - Gestão de Riscos
    - Identificar, avaliar e tratar riscos relacionados com a segurança da informação
  - Políticas e Controlo de Acesso
    - Definição de políticas e processos de segurança para proteger informações.
  - Melhoria Contínua:
    - Monitorizar e rever o SGSI para melhorias contínuas
- **Certificação**
  - Organizações podem certificar-se na ISO/IEC 27001 para demonstrar a sua conformidade com práticas de segurança da informação reconhecidas.

360

360

ISO/IEC 27002: Código de Boas Práticas para Controlo de Segurança da Informação

- É uma extensão da ISO/IEC 27001 e fornece orientações para implementar os controlos de segurança da informação.
- **Objectivo**
  - Ajudar as organizações a seleccionar controlos de segurança com base nos seus riscos e necessidades específicas.
- **Conteúdos principais**
  - Controlo de acessos, segurança física, protecção contra malware, gestão de vulnerabilidades, e segurança nas operações.

361

361

ISO/IEC 27003: Guia para a Implementação do SGSI

Especifica as directrizes para a implementação um SGSI de acordo com a ISO/IEC 27001.

- **Objectivo**
  - Facilitar a implementação do SGSI ao fornecer exemplos práticos, guias de planeamento e uma estrutura clara para a execução de um sistema de segurança eficaz.

362

362

ISO/IEC 27004: Medição da Segurança da Informação

Esta norma foca-se na avaliação da eficácia de um SGSI através da medição e monitorização.

- **Objectivo**
  - Ajudar as organizações a desenvolver métricas para avaliar e melhorar o desempenho do SGSI, garantindo que as medidas de segurança implementadas são eficazes

363

363

ISO/IEC 27005: Gestão de Risco em Segurança da Informação

- Fornece um quadro de trabalho para a gestão de risco de segurança da informação
- **Objectivo:**
  - Orientar as organizações na identificação, avaliação e tratamento de riscos, facilitando a aplicação de uma abordagem baseada em riscos, como recomendado pela ISO/IEC 27001
- **Práticas principais**
  - Identificação de activos, avaliação de ameaças, análise de vulnerabilidades e tratamento de riscos.

364

364

ISO/IEC 27017: Segurança da Informação para Serviços na Cloud

Descrição: Esta norma oferece directrizes específicas para a segurança da informação em ambientes de cloud computing, complementando a ISO/IEC 27002

- **Objectivo**
  - Ajudar prestadores e utilizadores de serviços de cloud a gerir riscos associados à segurança na nuvem.
- **Focos principais**
  - Controlo de acessos, protecção de dados em ambientes cloud, e partilha de responsabilidades entre fornecedores e clientes de serviços na nuvem.

365

365

ISO/IEC 27018: Protecção de Dados Pessoais na Nuvem (Privacidade na Cloud)

Descrição: Uma extensão da ISO/IEC 27017, focada na protecção de dados pessoais em ambientes cloud, em conformidade com regulamentos como o RGPD

- **Objectivo**
  - Garantir que fornecedores de serviços de cloud cumprem os requisitos de privacidade e protecção de dados.
- **Práticas principais**
  - Consentimento para o processamento de dados, gestão de privacidade por design, e requisitos para a eliminação de dados.

366

366

ISO/IEC 27031: Continuidade do Negócio e Resiliência

Esta norma foca-se na continuidade do negócio, abordando a preparação, resposta e recuperação em caso de interrupções

- **Objectivo**
  - Assegurar que as operações de segurança da informação permanecem funcionais durante crises, como falhas de sistemas, ciberataques ou desastres naturais
- **Principais componentes**
  - Planos de recuperação de desastres, estratégias de resposta a incidentes, e resiliência operacional.

367

367

ISO/IEC 27032: Ciber-segurança

Define directrizes para proteger o ciber-espaço e combater ameaças de segurança cibernética.

- **Objectivo**
  - Proteger contra ataques cibernéticos e promover uma comunicação segura entre sistemas
- **Abrangência**
  - Cobre aspectos de cibe-rsegurança como a protecção de redes e infraestruturas críticas, cibercrime, e colaboração entre partes interessadas.

368

368

ISO/IEC 27701: Gestão de Privacidade e Proteção de Dados (PIMS)

Esta norma complementa a ISO/IEC 27001, fornecendo directrizes para a gestão de informações de identificação pessoal (PII) e protecção de dados.

- **Objectivo**
  - Ajudar as organizações a cumprir os requisitos de privacidade e protecção de dados de acordo com regulamentos como o GDPR.
- **Componentes principais**
  - Estabelecimento de políticas de privacidade, procedimentos de consentimento e implementação de medidas para salvaguardar dados pessoais.

369

369

Vantagens da Implementação da Família de Normas ISO/IEC 27000

Implementar as normas ISO/IEC 27000 oferece várias vantagens para as organizações:

- **Melhoria na Gestão de Riscos**
  - Identificação e tratamento eficaz de riscos relacionados com a segurança da informação.
- **Conformidade**
  - Assegura que a organização cumpre com regulamentos e requisitos legais, como o RGPD
- **Reputação e Confiança**
  - A certificação nas normas ISO/IEC 27001 e afins aumenta a confiança de clientes e parceiros, demonstrando um compromisso com a segurança da informação
- **Eficiência e Melhoria Contínua**
  - Estabelecimento de processos de segurança eficientes, que são constantemente revistos e melhorados.
- **Resiliência e Continuidade**
  - Maior capacidade para reagir e recuperar de incidentes de segurança, ciberataques ou desastres.

370

370

Adaptação ...

- A implementação das normas da família 27000 deve ser ajustada à realidade e necessidades de cada organização.
- Contudo, juntas, elas formam uma estrutura robusta para a protecção da informação e a gestão de riscos, ajudando a criar ambientes mais seguros e preparados para desafios complexos de segurança da informação

371

371



OWASP (Open Web Application Security Project)

OWASP Top 10

372

372

OWASP (Open Web Application Security Project)

- organização sem fins lucrativos que se dedica à melhoria da segurança de software.
- Fundada em 2001, o OWASP visa ajudar as empresas, os programadores e as equipas de segurança a identificarem, compreenderem e mitigarem riscos de segurança nas aplicações
- O OWASP é amplamente reconhecido no sector pela criação de ferramentas, documentação e metodologias que ajudam a desenvolver software seguro.
- **Um dos projectos mais conhecidos da OWASP é o OWASP Top 10**
  - lista das 10 vulnerabilidades de segurança mais críticas em aplicações web.
  - Actualizada periodicamente (normalmente a cada 3-4 anos), esta lista serve como referência para os profissionais de segurança e desenvolvimento, ajudando-os a focar-se nas vulnerabilidades mais frequência e com maior impacto

373

373

Objectivo do OWASP Top 10

- **Aumentar a Consciencialização de Segurança**
  - Fornecendo uma lista das vulnerabilidades mais críticas, a OWASP ajuda os desenvolvedores a compreenderem os riscos mais relevantes
- **Facilitar a Prevenção de Vulnerabilidades**
  - Oferece práticas recomendadas e orientações para ajudar as equipas a mitigarem as falhas mais comuns.
- **Padronizar a Segurança em Aplicações Web**
  - Muitas organizações usam o OWASP Top 10 como base para auditorias de segurança e avaliações de conformidade, tornando-o uma norma de facto na segurança web.

374

374

OWASP Top 10

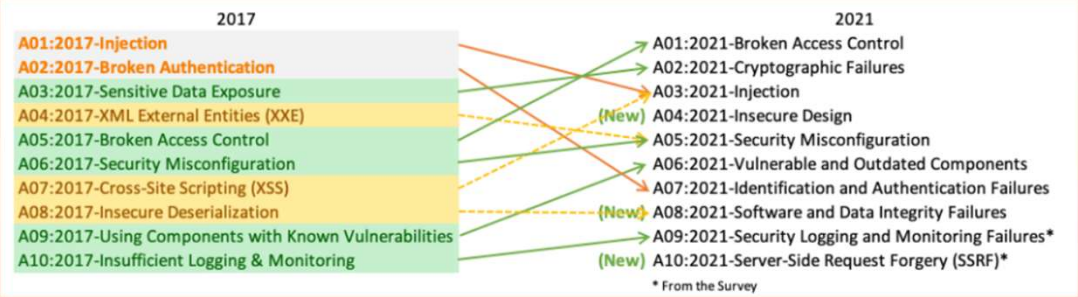
- O OWASP Top 10 é frequentemente utilizado como uma base para auditorias e verificações de segurança e serve de guia para implementar práticas de desenvolvimento seguro

375

375

OWASP Top 10 - Vulnerabilidades (2021)

- A versão mais recente do OWASP Top 10 foi publicada em 2021 (a próxima será publicada em 2025)



https://owasp.org/www-project-top-ten/

376

376

OWASP Top 10 - A01: Quebra de Controlo de Acesso

- **Descrição**
  - A falta de controlos adequados permite que utilizadores acedam a recursos ou funcionalidades sem autorização.
- **Exemplo**
  - Um utilizador sem privilégios consegue modificar ou aceder a dados restritos
- **Mitigação:**
  - Implementar controlos de acesso rigorosos e verificação de permissões.

377

377

OWASP Top 10 - A02: Falhas de Criptografia e Gestão de Dados Sensíveis

- **Descrição**
  - Dados sensíveis, como dados pessoais ou financeiros, não são protegidos adequadamente, ficando vulneráveis a roubo
- **Exemplo**
  - Dados não encriptados em armazenamento ou durante a transmissão
- **Mitigação:**
  - Encriptar dados sensíveis em trânsito e em repouso, utilizar algoritmos de encriptação fortes e cumprir regulamentações como o RGPD

OWASP Top 10 - A03: Injecção

- **Descrição**
  - Vulnerabilidades que permitem a execução de comandos maliciosos em bases de dados ou sistemas, através de input não validado.
- **Exemplo**
  - Injecção SQL, onde um atacante consegue manipular uma query de base de dados
- **Mitigação:**
  - Utilizar consultas parametrizadas, evitar a construção dinâmica de queries

OWASP Top 10 - A04: Design Inseguro

- **Descrição**
  - Aplicações desenhadas sem considerar medidas de segurança, deixando-as vulneráveis a vários tipos de ataques
- **Exemplo**
  - Falta de modelação de ameaças e análise de segurança na fase de design
- **Mitigação:**
  - Adoptar práticas de Secure by Design, realizar modelação de ameaças e considerar a segurança durante o planeamento e design

380

380

OWASP Top 10 - A05: Configuração de Segurança Incorrecta

- **Descrição**
  - Configurações inadequadas ou mal geridas deixam as aplicações expostas a ataques
- **Exemplo**
  - Ferramentas de administração expostas, permissões excessivas, ou configurações padrão
- **Mitigação:**
  - Realizar auditorias de configuração regularmente, remover funcionalidades e páginas desnecessárias e configurar permissões mínimas

381

381

OWASP Top 10 - A06: Componentes Vulneráveis e Desactualizados

- **Descrição**
  - A utilização de bibliotecas, frameworks e componentes desactualizados que têm vulnerabilidades conhecidas
- **Exemplo**
  - Uso de uma biblioteca de terceiros vulnerável que permite ataques como Cross-Site Scripting
- **Mitigação:**
  - Manter componentes actualizados, monitorizar vulnerabilidades e aplicar patches de segurança

382

382

OWASP Top 10 - A07: Autenticação e Gestão de Sessões Inseguras

- **Descrição**
  - Falhas na autenticação e gestão de sessões que permitem a invasão de contas de utilizador
- **Exemplo**
  - Armazenamento de palavras-passe em texto plano ou autenticação insuficiente
- **Mitigação:**
  - Utilizar autenticação multifator, encriptar palavras-passe com hashing seguro e implementar expiração de sessões inactivas

383

383

OWASP Top 10 - A08: Falha no Registo e Monitorização de Segurança

- **Descrição**
  - Falta de monitorização e registo de atividades impede a deteção e resposta a incidentes de segurança
- **Exemplo**
  - Ataques que passam despercebidos devido à ausência de registos e alertas
- **Mitigação:**
  - Implementar registos e alertas de segurança, e definir políticas de resposta a incidentes

384

384

OWASP Top 10 - A09: Falhas de Integridade de Software e Dados

- **Descrição**
  - Falhas em garantir a integridade de software e dados durante o ciclo de desenvolvimento.
- **Exemplo**
  - Utilização de software de terceiros não verificado que pode estar comprometido
- **Mitigação:**
  - Verificar a integridade de software e dados com assinaturas digitais, configurar pipelines CI/CD com controlos de segurança

385

385

OWASP Top 10 - A10: SSRF (Server-Side Request Forgery)

- **Descrição**
  - A aplicação pode ser manipulada para enviar pedidos não autorizados a serviços internos ou externos
- **Exemplo**
  - Um atacante manipula a aplicação para aceder a recursos internos através de uma falha na lógica de redireccionamento
- **Mitigação:**
  - Limitar e validar os pedidos de saída, configurar listas brancas de URLs, e desactivar redireccionamentos automáticos em serviços internos

386

386



Integração das normas da família ISO/IEC 27000 e o processo de desenvolvimento de software

387

387

Planeamento e Análise de Requisitos (Requisitos de Segurança e Privacidade)

- **ISO/IEC 27001 e ISO/IEC 27005**
  - Desde o início do projecto, estas normas ajudam a identificar e avaliar os riscos relacionados com a segurança e definir requisitos específicos para proteger dados e mitigar ameaças
- **ISO/IEC 27017 e ISO/IEC 27018**
  - Se o software for desenvolvido para ambientes cloud, estas normas orientam a análise de requisitos de segurança e protecção de dados específicos para a cloud
- **ISO/IEC 27701**
  - A gestão de privacidade e protecção de dados pessoais é crucial no início do projecto, especialmente em conformidade com regulamentos como o RGPD
  - Ajuda a definir os requisitos de privacidade e protecção de dados desde a fase de planeamento.

388

388

Desenho e Arquitectura de Software

- **ISO/IEC 27001**
  - Durante o desenho da aplicação, o sistema de gestão de segurança da informação assegura que são definidos controlos e políticas para mitigar riscos e proteger activos de informação
- **ISO/IEC 27002**
  - Fornece boas práticas para a aplicação de controlos, como autenticação segura, encriptação e gestão de sessões, que devem ser integrados no desenho da aplicação
- **ISO/IEC 27032 (Ciber-segurança)**
  - Assegura que as aplicações são desenhadas para proteger o ciberespaço contra ameaças e ataques, orientando as equipas a desenharem com práticas de ciber-segurança robustas, como prevenção de ataques de DDoS ou de engenharia social
- **ISO/IEC 27017 e ISO/IEC 27018**
  - Ajudam a integrar aspectos de segurança específicos da cloud (como partilha de responsabilidades entre cliente e fornecedor de cloud) no design de aplicações que serão implementadas na nuvem.

389

389

Desenvolvimento e Codificação

- **ISO/IEC 27002 e OWASP**
  - A ISO/IEC 27002 complementa os padrões **OWASP Top 10 ,** que orientam as equipas para implementar controlos e práticas de segurança durante a codificação. Incluem práticas como a validação de entradas de dados, autenticação segura e gestão de erros
- **ISO/IEC 27001 e ISO/IEC 27005**
  - Mantêm a abordagem baseada no risco e asseguram que os requisitos de segurança e os controlos definidos na fase de planeamento são aplicados durante a codificação
- **ISO/IEC 27018**
  - Se forem tratados dados pessoais, esta norma ajuda a garantir que o código incorpora medidas de proteção de dados, como a pseudonimização e encriptação de dados sensíveis, cumprindo requisitos legais.

390

390

Testes e Verificação de Segurança

- **ISO/IEC 27001**
  - A norma assegura que o SGSI implementa uma política de testes de segurança para verificar a conformidade com os requisitos de segurança
- **ISO/IEC 27002**
  - Fornece diretrizes para realizar testes de segurança, como testes de penetração, auditorias de código e revisões de segurança que avaliam a eficácia dos controlos implementados.
- **OWASP**
  - O OWASP Top 10 é fundamental nesta fase, pois fornece uma lista de vulnerabilidades comuns que devem ser testadas. O ASVS (Application Security Verification Standard) ajuda a garantir que todas as verificações de segurança relevantes foram implementadas.
- **ISO/IEC 27004 (Medição de Segurança)**
  - Ajuda a definir métricas de segurança para avaliar a eficácia dos controlos de segurança e dos testes implementados, garantindo que as vulnerabilidades detectadas são adequadamente tratadas.

391

391

Manutenção e Operação

- **ISO/IEC 27001 e ISO/IEC 27002**
  - Durante a fase de operação, estas normas guiam a gestão de segurança e a resposta a incidentes. Promovem a monitorização e a revisão contínuas para garantir que as aplicações permanecem seguras.
- **ISO/IEC 27005**
  - A norma ajuda a gerir riscos de segurança que surgem após o lançamento da aplicação, assegurando a avaliação e tratamento de novas ameaças
- **ISO/IEC 27032**
  - Oferece orientações para proteger o ciberespaço, garantindo a segurança das operações e da infraestrutura de rede em produção contra ameaças de ciber-segurança
- **ISO/IEC 27018**
  - Na operação de sistemas que tratam dados pessoais, a norma garante que as práticas de privacidade e conformidade continuam a ser cumpridas e que há protecção contínua contra acessos não autorizados
- **ISO/IEC 27701**
  - Mantém a gestão de privacidade para garantir que os dados pessoais são tratados conforme os direitos dos titulares e as regulamentações.

392

392

Monitorização e Auditoria

- **ISO/IEC 27004**
  - Facilita a monitorização contínua da segurança através de métricas e KPIs (indicadores chave de desempenho) que permitem avaliar a eficácia dos controlos de segurança implementados
- **ISO/IEC 27001 e ISO/IEC 27002**
  - A norma orienta a realização de auditorias internas para verificar a conformidade com o SGSI, identificar e resolver falhas de segurança
- **ISO/IEC 27701**
  - Assegura que as auditorias também verificam a conformidade com os requisitos de privacidade e a proteção de dados pessoais

393

393


isec
Politécnico de Coimbra
Gestão de Projecto de Software
Licenciatura em Engenharia Informática
2024/2025
A12
394

394